

Response to Reviewers

Governance Requirements for Coordinating Clinical AI Agents

Bruce Changlong Xu, Ayush Chopra, and Alexander J. Ryu

We thank the reviewers for their careful and constructive assessments. The manuscript has been substantially restructured in response. Most importantly, we no longer present CIRC as a four-level maturity model, a validated architecture, or a proposed standard. The revised manuscript defines CIRC as a non-exhaustive taxonomy of clinical-agent risks and a set of independent governance levers that can be implemented through existing standards, local infrastructure, or different architectural patterns.

The original toy simulations, quantitative performance-style claims, oncology vignette, and population-level clinical prediction example have been removed. CliniCARE-Bench is now used only as a worked example of trace-observable agent-local risk. The manuscript states repeatedly that this single-agent benchmark does not validate CIRC or test multi-agent coordination. Interaction, workflow, institutional, and clinical-outcome claims remain an evaluation agenda rather than reported findings.

The comments below are faithful paraphrases of the reviewer concerns rather than quotations.

Reviewer 1

Comment 1: Clarify the central contribution and the relationship between individual-agent and multi-agent safety

Response. We made interaction risk the organizing problem of the manuscript. The Introduction now distinguishes failures in an agent’s own investigation from failures created by shared state, dependencies, handoffs, finite resources, and institutional response. The revised risk taxonomy separates agent-local, interaction-and-workflow, and system-and-institutional risks, while noting that a single event can occupy more than one domain.

Comment 2: The four CIRC levels imply an unvalidated progression or maturity hierarchy

Response. We removed the four-level structure in full. CIRC now contains seven independent levers: identity and attribution; scope and authorization; structured intent and shared state; dependency coordination; resource and population awareness; operational human oversight; and monitoring and failure containment. Deployments may select different combinations and strengths according to their risk profile. The manuscript states that the levers are neither individually necessary nor collectively sufficient and do not form a cumulative sequence.

Comment 3: The simulations require methodological support and should not be presented as evidence of effectiveness

Response. We removed all three toy simulations, their figures, and the associated numerical claims rather than moving them to supplementary material. The revised paper reports no experiment purporting to show that CIRC improves clinical or operational outcomes. It instead separates three future evaluation questions: whether a risk is observable, whether a control detects or contains it while preserving valid work, and whether the control improves outcomes. The last question is explicitly reserved for prospective evaluation.

Comment 4: Ground the framework in concrete, measurable behavior

Response. We added operational definitions of interaction risk, collision, scope violation, dependency violation, and failure containment. We also added a non-normative structured coordination message with identity, delegated authority, patient and encounter context, state version, dependencies, expiry, reversal, escalation, and provenance fields. Each governance lever is now linked to illustrative observable evidence.

Reviewer 2

Comment 1: CIRC is presented inconsistently as a taxonomy, maturity model, architecture, protocol, and governance framework

Response. We adopted one narrower claim throughout. CIRC is now described as an architecture-neutral governance framework that connects a non-exhaustive risk taxonomy to candidate controls and evidence requirements. It is not presented as a wire protocol, implemented architecture, certification scheme, or deployment-ready standard.

Comment 2: The manuscript does not establish why the proposed controls are distinct from existing standards and infrastructure

Response. We replaced the broad insufficiency claim with two structured comparisons. The first identifies capabilities already provided by FHIR, SMART on FHIR, CDS Hooks, A2A, MCP, and workflow and policy engines, then separates residual semantics, authorization, workflow, governance, and portability questions. The second maps every CIRC lever to existing substrate, the residual contract and gap type, and illustrative evidence. We now state directly that profiles, extensions, workflow engines, policy engines, EHR-native services, or local governance may implement many or all needed controls without a new transport protocol.

Comment 3: The seven levers require a derivation and should not be claimed as minimal or sufficient

Response. We added the selection rationale. The seven levers are a functional decomposition of the operational questions a deployment must answer: who acted, whether the action was permitted, what state and intent governed it, which dependencies applied, whether shared resources were affected, who assumed responsibility, and how failure was contained. We explicitly characterize this as a starting point rather than an empirical derivation or closed ontology. Privacy, transport security, clinical validation, and model performance remain cross-cutting obligations outside this decomposition.

Comment 4: Central orchestration and other architectures may address the same risks without direct agent-to-agent communication

Response. We agree. The revised manuscript compares central workflow orchestration, EHR-native workflow control, policy and identity layers, supervisory agents, distributed agent protocols, and human-led coordination. The architecture figure is labeled as one possible centralized realization, not a required topology. The manuscript now treats protocol fields as most useful at organizational or vendor boundaries and does not prefer decentralized communication over orchestration.

Comment 5: The coordination layer creates its own common-mode and security risks

Response. We added a failure model covering compromised identity, stale or replayed messages, incorrect dependency graphs, deadlock and retry amplification, misleading resource signals, coordination-service outage, network partition, and failure of the human control path. The revised text requires deployment-specific trust anchors, revocation, state guarantees, and degraded behavior. It also distinguishes safe modes for read-only, reversible administrative, consequential clinical, and emergency actions, and specifies how control returns to a named role.

Comment 6: Human review is not an operational control unless ownership and non-response behavior are specified

Response. We replaced generic human-review language with an operational escalation contract. It includes an accountable role and assignee, trigger and evidence, requested action, urgency and deadline, blocked or continuing state, fallback recipient and behavior, and a closure event. The manuscript also identifies suspension and revocation authority, separation of duties, duplicate-alert suppression, alert budgets, and measurable assignment, acknowledgement, fallback, override, and closure outcomes.

Comment 7: The oncology vignette and population-level prediction claim extend beyond coordination governance

Response. We removed the oncology vignette and the population-derived clinical prediction claim. Resource and population awareness is now limited to operational concerns such as capacity, demand, priority, concentration, fairness, and common-mode failure. Any population-level clinical prediction is explicitly described as a separate model requiring independent development and validation.

Reviewer 3

Comment 1: Define the actors, terms, and proposed information exchange more precisely

Response. The revised Introduction defines a clinical agent and distinguishes administrative, supervised clinical, and clinically consequential agents. The operational-definitions subsection makes the principal failure terms testable, and the structured-message example shows the information that a receiver would need to authenticate an actor, evaluate authority, compare state, enforce prerequisites and expiry, deduplicate retries, and route unresolved conflict. The example can map to a FHIR profile, A2A extension, or local workflow schema and is explicitly non-normative.

Comment 2: Explain the relationship between CIRC and the Ripple Effect Protocol

Response. We now state that the Ripple Effect Protocol motivates a possible population-level failure pattern but does not validate CIRC, establish transfer to healthcare, or define a required CIRC mechanism. CIRC does not require REP’s sensitivity-sharing approach. Aggregate demand or sensitivity signals are described only as one candidate implementation that would require separate privacy, manipulation, fairness, workflow, and clinical-safety evaluation.

Comment 3: Map CIRC to concrete regulatory duties and identify what the framework does not resolve

Response. We rewrote the regulatory section at the level of individual software functions, intended use, statutory role, and deployment context. The U.S. discussion distinguishes non-device clinical decision support from device software functions and explains the limited evidentiary role of predetermined change control plans. The EU discussion maps Articles 9, 12, 14, 15, 17, 26, and 72 to risk management, record keeping, oversight, robustness, quality management, deployer duties, and post-market monitoring. A new table separates existing obligations, CIRC operational evidence, and questions CIRC cannot decide, including classification, conformity assessment, safety and effectiveness, intended use, liability, staffing, and local law.

Comment 4: Strengthen the scientific and standards grounding and remove unsupported claims

Response. We audited the bibliography and removed sources retained only for the deleted vignette or superseded regulatory discussion. Every retained bibliography entry is now cited in the text. The revised manuscript adds workflow, state-machine replication, zero-trust, sociotechnical safety, automation, and systems-theoretic safety sources where those concepts are used. Claims of novelty, necessity, sufficiency, validation, clinical benefit, and regulatory conformity have been narrowed or removed.

Summary of the revised evidentiary claim

The revised manuscript does not claim that CIRC has been empirically validated. Its contribution is a starting vocabulary and crosswalk connecting clinical-agent risks, governance controls, existing infrastructure, and observable evidence. CliniCARE-Bench illustrates only that some agent-local governance properties can be assessed from traces. Multi-agent replay, system stress testing, prospective shadow deployment, and monitored clinical use remain future work.